

Thaura.ai Technical & Functional Quality Assessment Report

Comprehensive Evaluation of AI Chat Application, Web Platform Architecture, Security Posture, Performance Benchmarks, and AI in SQA

POSITION UNDER EVALUATION

Software Quality Assurance Engineer

ASSESSMENT DATE

September 15, 2026

TEST ENVIRONMENT

Windows 11 / Chrome 128 / Edge 128 / Python 3.13

TARGET ENDPOINTS

<https://thaura.ai> & <https://backend.thaura.ai>

27

DEFECTS
DOCUMENTED

57

TOTAL TEST CASES

94.3%

CHAT APP PASS RATE

54.4

REQ/SEC LOAD
BASELINE

Executive Summary

This report documents the end-to-end Quality Assurance assessment performed on **Thaura.ai** (an enterprise-focused, privacy-first AI platform). The scope spans functional testing of the flagship chat application, automated security audits, client-side web vital performance, backend API contract testing, load stress profiling, and strategic reflection on modern AI in software quality engineering.



Key Architectural Discovery: Thaura utilizes a completely passwordless authentication architecture relying on email verification codes (OTP). For web chat sessions, authentication is maintained via a secure, HttpOnly cookie (`thaura_token`), while developer API integrations authenticate via standard Bearer tokens against `POST /v1/chat/completions` .

Table of Contents

1. Task 01: Thaura Chat App Comprehensive Evaluation	Page 3
• 1.1 Account & Session Management Flow	Page 3
• 1.2 Free-Tier Rate Limiting & Quota Verification	Page 3
• 1.3 Multimodal File Uploads & Calculation Accuracy	Page 4
• 1.4 Memory Persistence vs. Incognito Mode Isolation	Page 4
• 1.5 Prompt Injection & Boundary Security	Page 5
• 1.6 Developer API Contract Tests (POST <code>/v1/chat/completions</code>)	Page 5
2. Task 02: Thaura.ai Website Technical Testing	Page 6
• 2.1 Route & Link Crawler Audit (404 Detection)	Page 6
• 2.2 Contact Form Functional & Security Verification	Page 6
• 2.3 Pricing Consistency (Interactive Toggle vs. SSR Crawler)	Page 7
• 2.4 SEO, Meta Tags, and Heading Structure	Page 7
• 2.5 Core Web Vitals (Lighthouse) & Autocannon Load Testing	Page 8
• 2.6 Security Headers & Session Cookie Attributes	Page 8
3. Task 03: AI & Software Testing Strategic Reflection	Page 9
4. Master Defect Management Register (27 Bugs)	Page 10

1. Task 01: Thaura Chat App Comprehensive Evaluation

Testing was conducted on the core AI chat product accessed through "Talk to Thaura" (URL: `https://thaura.ai/`). Evaluation combined live browser automation, network request interception via DevTools, and headless script invocations.

1.1 Account & Session Management Flow

Thaura implements a passwordless, email-based OTP verification workflow. Key findings include:

Signup Flow (TC-01): Successfully registered test account (`tamaljalam15@gmail.com`). The system requires User's Name and Gmail, dispatches a 6-digit verification code, and establishes an active chat session immediately upon verification.

Login Authentication Flow (TC-02): The platform does not provide a conventional password login field. Users access their accounts through "Try Thaura AI", enter their registered email, and re-authenticate via a new verification code.

Concurrent Browser Sessions (TC-05): Tested concurrent active sessions across Google Chrome 128 and Microsoft Edge 128. Prompts sent simultaneously from both browsers executed seamlessly without kicking either session or invalidating credentials.

Server-Side Logout Invalidation (TC-06): PASSED Captured active session token `thaura_token` before logging out. Upon clicking "Log Out", replaying POST requests to `/v1/chat/completions` with the captured token returned `401 Unauthorized` :

```
{
  "error": {
    "message": "Authentication required. Provide a valid API key (Authorization: Bearer YOUR_API_KEY)"
  }
}
```

This confirms server-side JWT revocation / token blacklisting is active on the backend.

1.2 Free-Tier Rate Limiting & Quota Verification

Policy Verification: The assessment prompt specified "5 messages / 2 hours". Live testing and reverse-engineering of backend response headers confirmed the actual production rate limit is **5 messages every 5 hours**.

TEST ID	TEST SCENARIO	EXPECTED RESULT	ACTUAL OBSERVED RESULT	STATUS
TC-08	Sequential Free Messages (1-5)	All 5 messages accepted	Prompts 1 to 5 processed normally with full streaming completions.	PASS
TC-09	6th Message Enforcement	Blocked by rate limiter with 429	HTTP 429 returned: <code>{ "error": { "type": "rate_limit_exceeded", "message": "Free users can send 5 messages every 5 hours. Upgrade for unlimited messages.", "resetAt": "..."} }</code>	PASS
TC-10	UI Quota Visibility	Visible countdown/counter	BUG-025: Chat UI provides zero counter or warning before the 429 block is triggered.	FAIL (UX)

TEST ID	TEST SCENARIO	EXPECTED RESULT	ACTUAL OBSERVED RESULT	STATUS
TC-11	Cross-Tab Enforcement	Global account enforcement	Rate limit persisted across multiple open tabs under the same account.	PASS
TC-12	Direct API Bypass Attempt	Blocked at backend level	Direct API requests with active token received HTTP 429; bypass impossible.	PASS
TC-14	Failed Request Accounting	400 errors do not count	Malformed requests returning 400 Bad Request did not decrement message quota.	PASS

1.3 Multimodal File Uploads & Calculation Accuracy

Thaura was evaluated against diverse file types and boundary limits to assess data extraction and ingestion fidelity:

FILE FORMAT	TEST SCENARIO	EXPECTED BEHAVIOR	ACTUAL RESULT	STATUS
PDF (.pdf)	Upload document containing financial math; prompt calculation.	Extract tabular numerical values and compute exact sum.	Returned exact mathematical result: 50000 .	PASS
Excel (.xlsx)	Upload structured spreadsheet; prompt column aggregation.	Parse Excel cells, columns, and headers correctly.	Extracted spreadsheet structure with 100% calculation accuracy.	PASS
Image (.png)	Upload photo of a cat; prompt detailed visual description.	Identify subject, breed traits, and visual composition.	Vision model generated accurate, descriptive breakdown of the subject.	PASS
Empty (0-byte)	Upload 0-byte blank file.	Client/server validation blocks upload.	Blocked immediately: <i>"Cannot upload empty file."</i>	PASS
Oversized Media	Upload audio file exceeding 50MB.	Boundary limit enforced with size notification.	Blocked immediately: <i>"Audio file size exceeds the 50MB limit."</i>	PASS

1.4 Memory Persistence vs. Incognito Mode Isolation

Thaura advertises private sessions and conversation memory. We tested both normal state retention and Incognito partition integrity:

- Conversational Multi-Turn Recall (TC-21):** In standard chat, the user introduced their name. Across 6 subsequent conversational turns, Thaura maintained perfect context continuity and recalled user details accurately.
- Incognito History Suppression (TC-22):** Conducted a complete conversation in Incognito Mode. Upon exiting Incognito, the session did not appear in the left-hand persistent chat history sidebar.
- Memory Leakage Isolation (TC-23):** Shared a confidential "secret verification code" exclusively within an Incognito session. After terminating Incognito and initiating a standard chat, Thaura was prompted: *"What is my secret code?"* Thaura responded that it had no knowledge or record of any secret code. Complete partition isolation confirmed.

1.5 Prompt Injection & Boundary Security

Malicious inputs and boundary conditions were supplied directly to the chat interface to evaluate safety alignment:

Blank / Whitespace Input (TC-24): Send button is dynamically disabled when the input field is empty or contains only whitespace characters, preventing empty message spam.

Extended Input Buffer (TC-25): Injected a prompt exceeding 5,000 characters. The message was accepted and parsed cleanly without browser DOM freeze, memory leaks, or truncation.

SQL Injection & XSS Attack Payloads (TC-26): Tested malicious strings: `' ; DROP TABLE users; --` and `<script>alert('xss')</script>`.

Observation: Thaura's system alignment recognized the attack vectors and neutralized them:



No execution occurred; text was sanitized and rendered safely as literal text.

Multilingual / RTL Formatting (TC-27): Injected Arabic text (مرحبا بالعالم) alongside emojis and markdown code fences. Text rendered cleanly with correct right-to-left layout and intact typography.

1.6 Developer API Contract Testing (POST /v1/chat/completions)

Automated contract verification was executed using `scripts/api_tests.py` against the production backend. The endpoint conforms to OpenAI-compatible specifications with Thaura-specific nuances:

CATEGORY	TEST CASE	HTTP STATUS	RESPONSE BEHAVIOR	STATUS
Auth	Missing Authentication Header	401 Unauthorized	Rejects with <code>unauthorized</code> error code.	PASS
Auth	Malformed Bearer Token	401 Unauthorized	Properly rejects invalid key format.	PASS
Model	Invalid Model Identifier (<code>thaura-x</code>)	400 Bad Request	<code>"Only 'thaura' model is supported."</code>	PASS
Model	Valid Model Identifier (<code>thaura</code>)	200 OK	Returns standard chat completion object.	PASS
Streaming	Server-Sent Events (<code>stream: true</code>)	200 OK	Delivers SSE stream (<code>text/event-stream</code>).	PASS
Headers	Response Security Headers	200 OK	BUG-026: Duplicate headers returned (HSTS, X-Frame-Options).	FAIL (CONFIG)

2. Task 02: Thaura.ai Website Technical Testing

Testing covered automated link crawling, functional contact form validation, pricing consistency, SEO audits, Lighthouse Core Web Vitals, Autocannon stress testing, and security headers across public routes.

2.1 Route & Link Crawler Audit (404 Detection)

Automated crawl via `scripts/link_checker.py` parsed **282 links across 9 core routes**. The scan identified **3 critical broken routes (P1 High Severity)**:

BUG ID	ROUTE / URL	STATUS	BUSINESS & TECHNICAL IMPACT
BUG-015	<code>https://thaura.ai/apps</code>	404	App download page is completely missing, blocking desktop/mobile user acquisition.
BUG-016	<code>https://thaura.ai/privacy</code>	404	Severe GDPR Compliance Defect: Thaura markets privacy and GDPR compliance, yet its Privacy Policy route returns a dead 404 page.
BUG-017	<code>https://thaura.ai/terms</code>	404	Terms of Service page returns 404 Not Found, exposing platform to legal ambiguity.

2.2 Contact Form Functional & Security Verification

Manual testing was conducted on the sales inquiry form (TC-W01 to TC-W07):

Blank Submission (TC-W01): Required fields are Name, Email, and Message. Empty submissions are intercepted by HTML5 form validation displaying *"Please fill out this field."*

Email Format Validation (TC-W03): Submitting `notanemail` triggers browser email constraint validation: *"Please include an '@' in the email address. 'notanemail' is missing an '@'."*

Successful Dispatch (TC-W05): Valid submission successfully returns green confirmation toast: *"Message sent successfully! We'll get back to you soon."*

XSS & Script Neutralization (TC-W06): Injected `<script>alert(1)</script>` into message body. String was treated strictly as plain text, with zero DOM execution.

2.3 Pricing Consistency: Interactive Toggle vs. SSR Crawler Disparity

Key SQA Resolution: Live manual execution resolved an apparent math inconsistency detected during initial automated crawling.

BILLING FREQUENCY	DISPLAYED PRO PRICE	BILLED SUBTEXT	MATHEMATICAL VERIFICATION
Monthly	\$15 / month	Standard monthly cycle	$\$15 \times 12 = \180 / year (Matches FAQ price)
Annual (Save 20%)	\$12 / month	"Billed \$144 / year"	$\$180 \times 0.80 = \textbf{\$144 / year}$ (\$12/mo) • Exact 20% savings!

The Defect (BUG-020): While the client-side JavaScript toggle executes mathematically sound calculations, the initial SSR HTML payload defaults to displaying `$12` without showing the `$15` base rate, causing web crawlers and search indexers to flag an apparent math error (`$12 × 12 = $144` showing "Save 20%").

2.4 SEO & Meta Tag Compliance

Audited via `scripts/meta_tag_audit.py` across all routes:

Missing <h1> on Root (BUG-002 / BUG-019): The root URL (`https://thaura.ai/`) contains zero `<h1>` tags in its rendered source, violating basic SEO heading hierarchy. (Note: `/home` has a proper H1).

Canonical Mismatch (BUG-001 / BUG-018): The canonical link on `https://thaura.ai/` points to `https://thaura.ai/home` , creating canonical ambiguity between the root and home paths.

Meta Tags: All valid pages implement complete OpenGraph (`og:title` , `og:image` , `og:description`) and Twitter Card tags.

2.5 Core Web Vitals (Lighthouse) & Autocannon Load Testing

Lighthouse 13.4.1 performance audits revealed high desktop scores, with opportunities for LCP optimization:

PAGE ROUTE	PERFORMANCE	ACCESSIBILITY	BEST PRACTICES	SEO	LCP
Homepage (<code>/</code>)	91 / 100	95	96	92	3.1s ⚠️
Pricing (<code>/pricing</code>)	99 / 100	95	96	92	1.3s ✅
FAQ (<code>/faq</code>)	88 / 100	92	96	92	3.2s ⚠️
API (<code>/api-platform</code>)	96 / 100	95	96	92	2.1s ✅

Autocannon Load Test Summary: Under 10 concurrent connections over 10 seconds, the frontend sustained **54.40 requests/sec** (544 total requests) with an average latency of **106 ms** and an absolute **0% error rate**.

Production Console Error (BUG-024): DevTools Console revealed an uncaught runtime exception on the homepage: `Uncaught TypeError: Cannot read properties of undefined (reading 'startTime')` at `et.reportAllChanges` , triggered by a missing null-check in the web-vitals reporting bundle.

2.6 Security Headers & Session Cookie Attributes

Audited via `scripts/security_header_check.py` and DevTools Application tab:

HSTS: `Strict-Transport-Security: max-age=31536000; includeSubDomains` • **PASS**

Clickjacking Defense: `X-Frame-Options: DENY` • **PASS**

MIME Sniffing Defense: `X-Content-Type-Options: nosniff` • **PASS**

Content Security Policy: Robust CSP configured with restrictive script-src and connect-src.

Session Cookie (`thaura_token`): Configured with `HttpOnly=True`, `Secure=True`, and `SameSite=Lax`. Protects against client-side script theft and cross-site forgery.

Cookie Expiration Finding (BUG-027): The JWT token expiration is set to **September 2027 (~1.5 years)** without rolling refresh token invalidation, presenting a long-term session hijacking risk.

3. Task 03: AI & Software Testing Strategic Reflection

1. How do you think AI will impact software testing over the next 2–3 years?

AI is transforming software testing from a manual, script-heavy discipline into a high-level strategic engineering role:

Context-Aware Test Automation: LLMs are advancing from simple boilerplate generation to synthesizing complex, business-logic-aware end-to-end integration scenarios directly from OpenAPI specs and product requirements documents.

Self-Healing Test Suites: Flaky tests and selector maintenance will decrease dramatically through AI-driven computer vision and DOM-graph self-healing locators that adapt to minor UI refactors automatically.

Augmented Exploratory Testing: AI agents will simulate chaotic user behavior, fuzz edge cases, and analyze application log telemetry to point human testers directly toward high-risk regression corridors.

The Core Risk (False Confidence): The greatest hazard is over-reliance. LLMs excel at pattern recognition but lack genuine systemic intuition. Teams that blindly trust AI-generated tests without critical coverage audits risk shipping novel, multi-tier edge-case defects into production.

2. Personal Practical Applications of AI in Daily QA Workflows

In modern daily SQA workflows, AI serves as an essential cognitive pair-programmer:

Matrix & Boundary Generation: AI accelerates test planning by generating combinatorial boundary test matrices (equivalence partitioning, negative injection strings, edge cases).

Automated Script Scaffolding: Complex Python, Playwright, or Autocannon test scaffolding is drafted rapidly, allowing the QA engineer to focus on assertion validity and edge conditions.

Log & Crash Analysis: Large JSON test outputs, Lighthouse profiles, and server telemetry are rapidly aggregated by AI to isolate anomalies and trace root causes.

3. Transparent Collaboration Note

Assessment Workflow Reflection: For this assessment, automated scripts and data extractors were scaffolded in collaboration with advanced AI tools. However, test design, manual execution, behavioral observations, security verifications, bug prioritization, and quality assessments represent genuine human analytical engineering.

4. Master Defect Management Register (27 Bugs)

The following register details all 27 verified defects discovered across Task 01 and Task 02, sorted by severity and logged in `Bug_Report_Updated.xlsx` :

BUG ID	SEVERITY	CATEGORY	DEFECT SUMMARY	RECOMMENDED ENGINEERING FIX
BUG-015	HIGH (P1)	Functional	Apps download page returns 404 Not Found	Deploy /apps landing page with desktop/mobile links.
BUG-016	HIGH (P1)	Compliance	Privacy Policy page returns 404 Not Found	Urgent: Publish Privacy Policy to satisfy GDPR regulations.
BUG-017	HIGH (P1)	Functional	Terms of Service page returns 404 Not Found	Publish legal Terms of Service page.
BUG-014	HIGH (P1)	Broken Link	Preconnect to Google User Content returns 404	Update preconnect URL to valid asset origin.
BUG-024	MEDIUM (P2)	Console Error	Uncaught TypeError: Cannot read 'startTime' of undefined	Add null guard in <code>et.reportAllChanges</code> telemetry handler.
BUG-025	MEDIUM (P2)	Usability	Chat UI lacks remaining message quota counter	Display message countdown badge (e.g. "X of 5 remaining").
BUG-026	MEDIUM (P2)	Backend Security	Duplicate and conflicting HTTP security headers	Deduplicate reverse-proxy headers in Nginx configuration.
BUG-020	MEDIUM (P2)	Data Correctness	SSR Pricing HTML shows $\$12 \times 12 = \144 with Save 20%	Render base \$15/mo in default SSR markup.
BUG-021	MEDIUM (P2)	Data Correctness	FAQ mentions \$15/month Pro price vs Pricing shows \$12	Harmonize static copy across FAQ and Pricing pages.
BUG-023	MEDIUM (P2)	Data Correctness	Rate limit claim mismatch (5 per 5h vs task spec)	Align documentation and task specs with live policy.
BUG-002	MEDIUM (P2)	SEO	Homepage (/) missing <code><h1></code> heading tag	Wrap main hero headline in semantic <code><h1></code> .
BUG-013	MEDIUM (P2)	Security Notice	Preconnect exposes backend API returning 401	Remove preconnect or configure public health probe.
BUG-027	LOW (P3)	Security	Excessive session token expiration period (~1.5 years)	Implement short-lived access tokens with refresh rotation.
BUG-001	LOW (P3)	SEO	Root URL canonical points to /home instead of /	Set canonical href on root to <code>https://thaura.ai/</code> .
BUG-022	LOW (P3)	Data Correctness	Inconsistent encryption claim verbosity (TLS vs AES)	Standardize security terminology across all public pages.

Complete Defect Register: Full reproduction steps, exact network request payloads, and console stack traces for all 27 bugs are archived in `Bug_Report_Updated.xlsx`.